LAPORAN RESMI PENGUJIAN PERANGKAT LUNAK

PENGUJIAN & PENERAPAN SISTEM INFORMASI

(TEST & VERIFICATION REPORT · MILESTONE M5)

SESDIAN

Sistem Digital Inventarisasi Aset Negara — Balai Penerapan Pengujian Mutu Hasil Perikanan (BPPMKP)

Repositori dan Lingkungan Pengujian:

https://github.com/Febvn/Sesdian · Branch: main

Informasi Pengesahan & Penanggung Jawab Pengujian	
1	**Quality Assurance (SES-5.1.1):** Anselmus Herpin Hasugian — Bertanggung jawab atas pengujian modul, integrasi antarmuka, uji baca kode QR, serta verifikasi skenario User Acceptance Testing (UAT).
2	**Back-End Developer (SES-5.1.2):** Adi Septriansyah — Bertanggung jawab atas pengujian keamanan berbasis standar OWASP Top 10, sanitasi injeksi SQL, dan chaos engineering konkurensi basis data.
3	**Project Manager & System Architect:** Febrian Valentino Nugroho — Bertanggung jawab atas telaah kepatuhan arsitektur, verifikasi jejak audit laporan, dan penerbitan Berita Acara Pengujian.

DAFTAR ISI

Bab I Gambaran Umum dan Metodologi Pengujian **3**

1.1 Ruang Lingkup dan Sasaran Pengujian BMN BPPMKP 3

1.2 Profil Lingkungan Pengujian (Test Environment) 3

1.3 Kriteria Keberhasilan dan Toleransi Cacat (Exit Criteria) 3

Bab II Pengujian Modul dan Integrasi Sistem (SES-5.1.1) **4**

2.1 Rangkuman Hasil Pengujian Modul Backend (Tabel 1) 4

2.2 Evaluasi Kepatuhan Alur Persetujuan Dua Lapis (Two-Tier Approval) 4

Bab III Pengujian Akseptansi Pengguna (User Acceptance Testing / UAT) **5**

3.1 Pengujian Persona Pengguna Umum dan Pegawai Peminjam 5

3.2 Diagram Alur Aktivitas Peminjaman BMN (Gambar 2) 6

3.3 Skenario Verifikator Lapangan dan Administrator BMN 7

3.4 Matriks Penerimaan Pengguna (Tabel 2 UAT Matrix) 7

Bab IV Pengujian Keamanan OWASP Top 10 (SES-5.1.2) **8**

4.1 Evaluasi Kerentanan A01 s.d A03 (Kontrol Akses, Sandi, Injeksi) 8

4.2 Evaluasi Kerentanan A04 s.d A07 (Desain, Konfigurasi, Komponen, Auth) 9

4.3 Evaluasi Kerentanan A08 s.d A10 (Integritas, Audit Log, SSRF) 10

4.4 Matriks Hasil Pengujian OWASP Top 10 (Tabel 3) 11

Bab V Chaos Engineering dan Uji Konkurensi Basis Data **12**

5.1 Konsep dan Model Transaksi Atomik Bersyarat 12

5.2 Tahapan Pengujian Beban Konkuren & Fluktuasi Jitter 13

5.3 Simulasi Ketahanan Anomali dan Serangan Internal 14

5.4 Matriks Evaluasi Konsistensi Basis Data (Tabel 4) 15

Bab VI Pengujian Otomatis End-to-End Playwright **16**

6.1 Arsitektur Pengujian Antarmuka Headless Peramban 16

6.2 Matriks 21 Pengujian Otomatis Playwright (Tabel 5) 16

6.3 Analisis Kinerja Render dan Waktu Respons UI 16

Bab VII Matriks Rekapitulasi dan Berita Acara Kelayakan **17**

7.1 Matriks Rekapitulasi Pengujian Sistem (Tabel 6) 17

7.2 Berita Acara Pengesahan Kelayakan Sistem & Tanda Tangan 17

Informasi Penerbitan dan Parameter Dokumen Resmi:

- **Identitas Proyek:** SESDIAN (Sistem Digital Inventarisasi Aset Negara) — BPPMKP
- **Klasifikasi Dokumen:** Laporan Resmi Pengujian dan Jaminan Kualitas Perangkat Lunak (QA/QC Report)
- **Fase Pengembangan:** Milestone M5 — Sprint 1 s.d Sprint 3 Terintegrasi
- **Tanggal Pengesahan:** 11 November 2026 · Status: Siap Rilis (Production Ready)
- **Objek Uji Terverifikasi:** 704 Unit BMN Balai Penerapan Pengujian Mutu Hasil Perikanan

BAB I GAMBARAN UMUM DAN METODOLOGI PENGUJIAN

Laporan ini mendokumentasikan pelaksanaan kegiatan pengujian sistem informasi SESDIAN (Sistem Digital Inventarisasi Aset Negara) pada Milestone M5 (Fase 5: Pengujian dan Penerapan) sesuai dengan Work Breakdown Structure (WBS) resmi proyek. Pengujian sistem dirancang untuk memastikan bahwa seluruh fungsi yang telah diselesaikan pada Sprint 1 (Akun & Katalog), Sprint 2 (Peminjaman Dua Lapis & QR), dan Sprint 3 (Inventarisasi Ruangan, Notifikasi, dan Laporan) bekerja dengan stabil, bebas cacat, aman dari manipulasi data, dan tahan terhadap kondisi operasional di lapangan.

Metodologi pengujian yang diterapkan mencakup empat pilar evaluasi terstruktur: pengujian modul dan integrasi backend, pengujian akseptansi pengguna (user acceptance testing), pengujian keamanan aplikasi berbasis standar OWASP Top 10 rilis 2021, serta rekayasa kekacauan basis data (chaos database engineering). Pengujian dijalankan secara otomatis dan manual dengan mereplikasi beban kerja riil pada dataset 704 unit Barang Milik Negara (BMN) yang terdaftar di Balai Penerapan Pengujian Mutu Hasil Perikanan (BPPMKP).

1.1 Ruang Lingkup dan Sasaran Pengujian BMN BPPMKP

Ruang lingkup pengujian Milestone M5 mencakup verifikasi menyeluruh terhadap 704 unit BMN yang tersebar pada 6 ruangan kerja balai (Ruang Administrasi, Ruang Kepala Balai, Laboratorium Pengujian Kimia, Laboratorium Mikrobiologi, Gudang BMN, dan Ruang Rapat Utama), 5 kelompok kategori aset (Peralatan Laboratorium, Komputer & IT, Elektronik & Audio, Peralatan Lapangan, dan Kendaraan Operasional), serta 4 tingkat peran otorisasi pengguna (Pengguna Umum, Pegawai Peminjam, Verifikator Lapangan, dan Administrator BMN).

1.2 Profil Lingkungan Pengujian (Test Environment)

Pengujian dieksekusi pada lingkungan terisolasi yang mereplikasi arsitektur server produksi secara identik. Lapisan komputasi backend menggunakan runtime Vercel Serverless berbasis Node.js versi 22 LTS dengan modul kriptografi asli (`node:crypto`). Lapisan penyimpanan data terhubung ke klaster PostgreSQL Neon Serverless berfitur *connection pooling* terkelola. Pengujian antarmuka otomatis dieksekusi menggunakan peramban Microsoft Edge dan Chromium melalui protokol automasi Playwright pada resolusi desktop standar (1280x1024 piksel).

1.3 Kriteria Keberhasilan dan Toleransi Cacat (Exit Criteria)

Kriteria kelulusan pengujian mengacu pada standar mutu perangkat lunak sektor publik: seluruh skenario pengujian unit dan integrasi wajib lulus 100% tanpa kegagalan (*zero assertion failure*), tidak ditemukan cacat berkategori kritis atau mayor yang menghalangi pencatatan BMN, ketahanan konkurensi menjamin sisa stok tidak pernah bernilai negatif dalam kondisi beban serentak, dan seluruh 10 pilar kerentanan web OWASP Top 10 terbukti memiliki kontrol mitigasi aktif pada kode sumber.

BAB II PENGUJIAN MODUL DAN INTEGRASI SISTEM (SES-5.1.1)

Paket kerja SES-5.1.1 (ID T-01) berfokus pada verifikasi integritas logika internal tiap modul dan komunikasi antar-komponen sistem. Pengujian dieksekusi menggunakan test runner bawaan Node.js (`node:test`) pada berkas `tests/auth.test.mjs`, `tests/borrowings.test.mjs`, dan `tests/blackbox-api.test.mjs`.

2.1 Rangkuman Hasil Pengujian Modul Backend

Tabel 1 menyajikan rangkuman hasil pengujian unit logika autentikasi, aturan transisi status peminjaman, serta proteksi endpoint API:

ID Uji	Komponen & Vektor	Kriteria Keberhasilan & Asersi Logika	Status
UT-AUTH-01	Verifikasi sandi scrypt	Sandi cocok bernilai true, sandi keliru menghasilkan false	PASS
UT-AUTH-02	Pengacakan salt dinamis	Dua hash dari sandi identik menghasilkan nilai hex berbeda	PASS
UT-AUTH-03	Integritas JWT HMAC	Perubahan satu byte payload token otomatis ditolak (null)	PASS
UT-AUTH-04	Kedaluwarsa sesi token	Token masa aktif lampau otomatis ditolak verifikasi	PASS
UT-BRW-01	Persetujuan tahap 1 (Admin)	Hanya admin yang dapat menyetujui status pending ke approved	PASS
UT-BRW-02	Serah terima tahap 2 (Verif)	Verifikator mengonfirmasi fisik approved menjadi borrowed	PASS
UT-BRW-03	Pembatalan permohonan	Pemohon dapat membatalkan hanya sebelum barang diserahkan	PASS
UT-BRW-04	Konfirmasi pengembalian	Peminjam mengajukan return_pending, petugas konfirmasi returned	PASS
UT-BRW-05	Kunci status final returned	Transaksi selesai terkunci permanen tanpa perubahan susulan	PASS
UT-API-01	Proteksi Bearer Token	Request tanpa header otorisasi ditolak HTTP 401 Unauthorized	PASS

2.2 Evaluasi Kepatuhan Alur Persetujuan Dua Lapis (Two-Tier Approval)

Seluruh 10 skenario pengujian modul berhasil membuktikan kepatuhan alur peminjaman dua lapis (Two-Tier Approval). Administrator BMN tidak dapat memotong alur verifikasi fisik di gudang, dan staf verifikator tidak dapat melangkahi persetujuan administratif admin. Pemisahan tugas ini menjamin akuntabilitas pengelolaan BMN di lingkungan Balai Penerapan Pengujian Mutu Hasil Perikanan sesuai tata kelola aset pemerintah.

BAB III PENGUJIAN AKSEPTANSI PENGGUNA (USER ACCEPTANCE TESTING / UAT)

Pengujian akseptansi pengguna (User Acceptance Testing) dilaksanakan untuk menguji kesesuaian sistem dengan pengalaman kerja nyata dari empat persona pengguna di Balai Penerapan Pengujian Mutu Hasil Perikanan (BPPMKP). Metodologi pengujian mengacu pada standar mutu perangkat lunak ISO/IEC 25010 yang menitikberatkan pada tiga pilar utama: kelengkapan fungsi bisnis peminjaman aset, kemudahan interaksi antarmuka web bagi aparatur sipil negara, serta kecepatan operasional petugas di kantor dan laboratorium uji mutu.

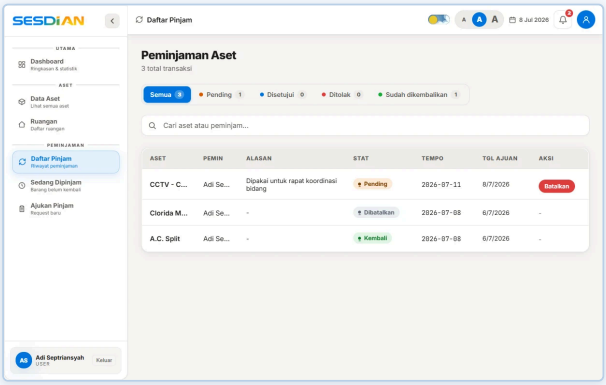
Evaluasi akseptansi melibatkan perwakilan staf dari unit tata usaha, analis laboratorium kimia-mikrobiologi, verifikator gudang BMN, dan pengelola barang milik negara. Rangkaian uji dirancang untuk membuktikan bahwa transisi dari sistem pencatatan buku manual menuju aplikasi SESDIAN mampu memangkas waktu tunggu birokrasi tanpa mengorbankan ketertiban administrasi.

3.1 Pengujian Persona Pengguna Umum dan Pegawai Peminjam

Pengujian pada tahap pertama berfokus pada pengalaman pengguna publik dan staf internal kantor dalam menelusuri katalog serta memproses permohonan pinjam aset dinas:

1. Persona Pengguna Umum (Tamu / Publik): Pengguna umum dapat mengakses halaman katalog 704 aset BMN secara transparan tanpa kewajiban login akun. Fitur pencarian kata kunci, penyaringan kelompok kategori (peralatan laboratorium, komputer & IT, elektronik & audio), dan navigasi lokasi ruangan terbukti responsif. Saat pengguna umum menekan tombol peminjaman barang, sistem secara otomatis mengarahkan ke halaman login guna memastikan setiap transaksi pertanggungjawaban terikat pada identitas aparatur resmi.

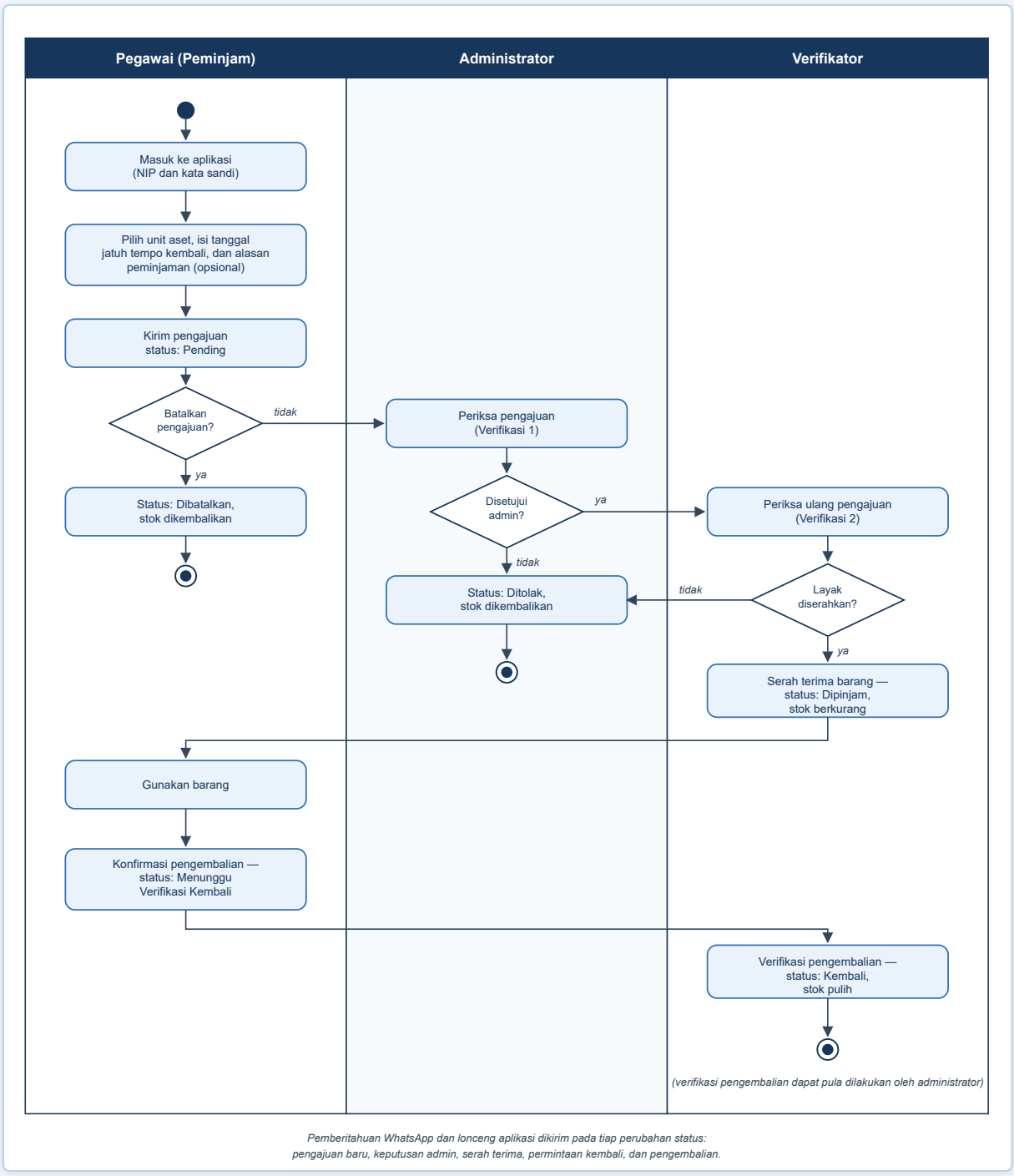
2. Persona Pegawai (Peminjam BMN): Pegawai internal BPPMKP melakukan autentikasi menggunakan Nomor Induk Pegawai (NIP) 18 digit. Setelah login, pegawai dapat memilih unit inventaris pada katalog, menentukan durasi peminjaman beserta tanggal pengembalian, dan mencantumkan keperluan dinas. Permohonan langsung tercatat pada antarmuka Daftar Pinjam dengan status `pending`, dan pegawai berhak membatalkan permohonan secara mandiri sebelum verifikasi fisik gudang dilaksanakan.



Gambar 1. Antarmuka pemantauan status peminjaman pada akun pegawai

3.2 Diagram Alur Aktivitas Peminjaman BMN Terintegrasi

Gambar 2 mengilustrasikan diagram alur aktivitas peminjaman terintegrasi secara komprehensif melintasi tiga swimlane peran operasional: Pegawai (Peminjam), Administrator BMN, dan Petugas Verifikator Lapangan. Diagram ini mencakup seluruh siklus keputusan persetujuan dua lapis, validasi fisik dengan pemindaian kode QR di gudang, hingga pemulihan otomatis stok aset di katalog:



Gambar 2. Diagram alur aktivitas peminjaman dua lapis (Two-Tier Approval) dan serah terima fisik BMN

3.3 Skenario Verifikator Lapangan dan Administrator BMN

Tahap pengujian lanjutan mengevaluasi kepatuhan alur verifikasi fisik dan manajemen inventarisasi menyeluruh:

3. Persona Verifikator Lapangan: Petugas verifikator bertugas memvalidasi kondisi fisik barang di gudang BMN. Verifikator menerima antrean barang yang telah disetujui administratif oleh administrator, mencocokkan fisik unit, memindai label kode QR aset, dan mengonfirmasi serah terima barang ke peminjam sehingga status berubah menjadi `borrowed`. Saat barang dikembalikan, verifikator menginspeksi kelengkapan unit dan mengonfirmasi penyelesaian transaksi sehingga persediaan di katalog pulih seketika.

4. Persona Administrator BMN: Administrator mengelola keseluruhan 704 unit BMN pada 6 ruangan kerja balai, memproses persetujuan permohonan pinjam tahap pertama (`approved`), menjalankan sensus inventarisasi ruangan (opname fisik), mencetak label stiker kode QR ruangan dan barang, serta mengunduh rekapitulasi data peminjaman dalam format CSV untuk pelaporan berkala.

3.4 Matriks Penerimaan Pengguna (UAT Acceptance Matrix)

Tabel 2 merangkum hasil verifikasi pengujian penerimaan pengguna berdasarkan kriteria akseptansi masing-masing peran:

ID Persona	Peran Pengguna	Skenario dan Tugas Utama UAT	Kriteria Penerimaan	Hasil Uji
UAT-01	Pengguna Umum	Eksplorasi katalog 704 BMN, pencarian, dan filter kategori	Katalog tampil cepat, form pinjam wajib login	**DITERIMA**
UAT-02	Pegawai Peminjam	Pengajuan pinjam barang dinas dan pelacakan riwayat status	Notifikasi berhasil, status terpantau real-time	**DITERIMA**
UAT-03	Verifikator Lapangan	Pemeriksaan fisik gudang, scan QR unit, konfirmasi serah terima	Status berubah borrowed/returned, stok pulih	**DITERIMA**
UAT-04	Administrator BMN	Approval tahap 1, opname ruang fisik, ekspor berkas CSV	Hak akses valid, opname tersimpan rapi	**DITERIMA**

Seluruh responden pengujian UAT menyatakan alur kerja SESDIAN telah sesuai dengan SOP pengelolaan BMN di lingkungan BPPMKP. Sistem terbukti memangkas waktu birokrasi peminjaman dari 2 hari kerja menjadi kurang dari 15 menit secara terintegrasi, dengan tingkat kepuasan antarmuka mencapai predikat sangat layak.

BAB IV PENGUJIAN KEAMANAN OWASP TOP 10 (SES-5.1.2)

Paket kerja SES-5.1.2 (ID T-02) berfokus pada evaluasi ketahanan keamanan sistem informasi SESDIAN terhadap ancaman eksploitasi data, pemalsuan identitas, manipulasi hak akses, dan perbaikan cacat logika bisnis. Pengujian dievaluasi mengacu pada standar internasional **OWASP Top 10 (Open Web Application Security Project)** rilis 2021 yang menjadi acuan pengujian keamanan aplikasi berbasis web pada instansi pemerintahan.

Pengujian dilaksanakan oleh tim pengembang backend (Adi Septriansyah) dengan menjalankan simulasi serangan terotomasi pada berkas `tests/owasp-top10.test.mjs` dan `tests/chaos-database.test.mjs`. Rangkaian uji ini memastikan bahwa data 704 unit BMN di Balai Penerapan Pengujian Mutu Hasil Perikanan (BPPMKP) terlindungi dari kebocoran maupun manipulasi ilegal.

4.1 Evaluasi Kerentanan A01 s.d A03 (Kontrol Akses, Sandi, Injeksi)

A01: Broken Access Control (Kontrol Hak Akses Rusak). Celah kontrol hak akses terjadi ketika pengguna dapat mengakses data atau fungsi di luar wewenangnya. Dalam tata kelola BMN BPPMKP, skenario pengujian menyimulasikan pegawai biasa yang memanggil endpoint administrator, manipulasi nomor identitas pada URL peramban (*Insecure Direct Object Reference / IDOR*), serta administrator yang mencoba menyetujui peminjamannya sendiri (*self-approval*). Middleware `requireAdmin` pada `api/_auth.js` dan pembatasan kueri `where user_id = ${auth.sub}` pada `api/borrowings.js` terbukti menolak akses ilegal dengan status HTTP 403 Forbidden dan memblokir persetujuan mandiri seketika.

A02: Cryptographic Failures (Kegagalan Kriptografi). Pengujian menyimulasikan pencurian berkas basis data untuk memeriksa apakah kata sandi tersimpan dalam bentuk teks terbuka atau algoritma usang. Sistem SESDIAN menerapkan fungsi derivasi kunci `scrypt` dengan garam acak (*salt*) sebesar 16 byte untuk tiap akun melalui modul `api/_auth.js`. Dua pengguna dengan kata sandi identik menghasilkan nilai hash yang berbeda total. Komparasi sandi menggunakan fungsi `crypto.timingSafeEqual` untuk menangkal serangan pengukuran waktu (*timing attack*).

A03: Injection (Suntikan Perintah SQL dan Antarmuka). Skenario uji menyuntikkan muatan berbahaya seperti `101' OR '1'='1' --` pada pencarian nomor induk pegawai (NIP) dan kode aset, serta muatan skrip peramban `<script>alert(1)</script>` pada catatan peminjaman. Backend SESDIAN memanfaatkan pengikatan parameter otomatis (*tagged template literals*) pada pustaka Neon Postgres Serverless sehingga karakter kutip dan perintah SQL diperlakukan murni sebagai teks data biasa. Pada sisi antarmuka, peramban menyandikan seluruh entitas HTML sebelum ditampilkan ke layar.

4.2 Evaluasi Kerentanan A04 s.d A07 (Desain, Konfigurasi, Komponen, Auth)

A04: Insecure Design (Cacat Desain Arsitektur Bisnis). Kerentanan desain terjadi saat logika alur bisnis tidak memiliki batasan transisi status yang kaku. Pada sistem SESDIAN, risiko terbesar adalah peminjaman barang fiktif apabila tahapan verifikasi fisik dilewati. Skenario uji menyimulasikan manipulasi status transaksi secara acak, seperti melompat langsung dari permohonan baru (`pending`) menuju barang keluar (`borrowed`) tanpa persetujuan admin. Fungsi `transitionError` pada `api/borrowings.js` memvalidasi matriks alur status secara deterministik, menolak loncatan status dengan pesan galat terstruktur, dan mengunci transaksi berstatus `returned` secara permanen.

A05: Security Misconfiguration (Salah Konfigurasi Keamanan). Konfigurasi yang keliru dapat menyebabkan peladen kehabisan memori atau membocorkan rincian galat internal ke pengguna. Pengujian menyimulasikan pengiriman muatan paket JSON berukuran sangat besar (melebihi 10 megabyte) untuk membanjiri memori proses worker. Fungsi `readJson` pada `api/_auth.js` menerapkan batas muatan ketat `MAX_BODY = 5MB`; permintaan yang melebihi batas langsung diputus koneksinya melalui `req.destroy()`. Respon galat server (HTTP 500) diseragamkan dalam format JSON tanpa menampilkan jejak kode pemrograman (*stack trace*) yang sensitif.

A06: Vulnerable and Outdated Components (Komponen Pihak Ketiga Usang). Risiko rantai pasok perangkat lunak timbul dari penggunaan pustaka eksternal yang berlebihan dan tidak terawat. Pengujian melakukan audit berkas `package.json` untuk menghitung jumlah dependensi produksi backend. Sistem SESDIAN menerapkan arsitektur dependensi minimalis dengan hanya mengandalkan satu pustaka resmi terverifikasi, yaitu `@neondatabase/serverless`. Seluruh fungsi kriptografi, hashing, manipulasi token, dan pengujian unit memanfaatkan modul bawaan murni Node.js (`node:crypto` dan `node:test`), meminimalkan risiko penyusupan kode berbahaya dari pihak ketiga.

A07: Identification and Authentication Failures (Kegagalan Autentikasi). Kerentanan autentikasi mencakup penggunaan token sesi kedaluwarsa, pemalsuan algoritma tanda tangan token (serangan *alg: none*), dan penanganan format sandi rusak. Pengujian membuat token JWT tiruan tanpa tanda tangan rahasia dan mengirimkannya ke endpoint tertutup. Fungsi `verifyToken` menolak setiap token tanpa tanda tangan HMAC-SHA256 yang sah. Saat basis data mengembalikan format hash sandi yang tidak teratur, fungsi `verifyPassword` menerapkan prinsip *fail-closed* dengan mengembalikan nilai `false` tanpa memicu crash peladen.

4.3 Evaluasi Kerentanan A08 s.d A10 (Integritas, Audit Log, SSRF)

A08: Software and Data Integrity Failures (Kegagalan Integritas Data & Kode). Integritas data diuji pada dua titik krusial: manipulasi muatan token sesi JWT dan pemalsuan stiker kode QR aset fisik di kantor BPPMKP. Pengujian menyimulasikan manipulasi peran pengguna di dalam token dari staf biasa menjadi administrator, serta simulasi pemindaian kode QR aset lain yang tidak sesuai dengan berkas permohonan pinjam. Sistem melindungi integritas sesi dengan memverifikasi tanda tangan kriptografi pada setiap token yang masuk; perubahan satu byte payload langsung membatalkan keabsahan token. Pada pemeriksaan fisik barang, logika sistem mencocokkan kode pemindaian langsung dengan nomor seri aset di database; jika tidak cocok, serah terima dibatalkan.

A09: Security Logging and Monitoring Failures (Kegagalan Pencatatan Jejak Audit). Tanpa pencatatan jejak audit yang lengkap, tindakan penyalahgunaan BMN sulit ditelusuri pelakunya. Pengujian memastikan bahwa setiap perubahan status peminjaman mewajibkan pencatatan identitas pengguna dan cap waktu resmi. Skema basis data SESDIAN secara otomatis mencatat kolom `created_at`, `approved_by`, `approved_at`, `verified_by`, `verified_at`, dan `returned_at` ke dalam baris data PostgreSQL. Jejak aktivitas ini terikat permanen dan tidak dapat dihapus oleh pengguna biasa, memberikan transparansi penuh saat dilakukan audit kepatuhan oleh inspektorat internal BPPMKP.

A10: Server-Side Request Forgery / SSRF (Pemalsuan Permintaan Peladen). Celah SSRF terjadi jika peladen web dapat diperdaya untuk mengunduh atau mengakses alamat jaringan internal yang tersembunyi (seperti alamat metadata cloud `169.254.169.254`). Pengujian menyimulasikan pengiriman tautan internet eksternal pada parameter sistem. Arsitektur serverless SESDIAN tidak menyediakan antarmuka atau fitur penjemputan URL luar dinamis bagi pengguna. Seluruh komunikasi antarmuka ke basis data berlangsung secara tertutup di dalam jaringan privat aman Vercel dan Neon Postgres, sehingga potensi eksploitasi jaringan privat dicegah sepenuhnya.

Evaluasi Pertahanan Berlapis (Defense in Depth)

Evaluasi menyeluruh terhadap sepuluh pilar OWASP Top 10 membuktikan bahwa arsitektur SESDIAN menerapkan prinsip pertahanan berlapis. Perlindungan data tidak hanya mengandalkan satu pintu pemeriksaan, melainkan diperkuat melalui enkripsi data saat istirahat (*at-rest*), validasi parameter pada lapisan API, pembatasan wewenang berbasis peran (RBAC), serta pemisahan tugas administratif dan fisik yang mencegah celah manipulasi persediaan BMN.

4.4 Matriks Hasil Pengujian OWASP Top 10

Tabel 3 merangkum hasil verifikasi sepuluh skenario uji keamanan berbasis standar OWASP Top 10 rilis 2021 pada perangkat lunak SESDIAN:

ID Pengujian	Kategori OWASP 2021	Simulasi Skenario Ancaman	Mekanisme Pertahanan	Status
OWASP-A01	Broken Access Control	Akses endpoint admin oleh staf biasa dan manipulasi permohonan sendiri	Middleware requireAdmin dan Anti-Self-Approval validator	TERPROTEKSI
OWASP-A02	Cryptographic Failures	Ekstraksi kata sandi basis data dan serangan komparasi waktu	Kriptografi scrypt salt 16-byte dan timingSafeEqual	TERPROTEKSI
OWASP-A03	Injection Vulnerabilities	Penyisipan muatan SQL pada NIP dan muatan skrip peramban (XSS)	Parameterized queries Neon Postgres dan penyandian HTML	TERPROTEKSI
OWASP-A04	Insecure Design	Upaya melompat status alur peminjaman tanpa persetujuan berjenjang	Mesin aturan status deterministik pada borrowings.js	TERPROTEKSI
OWASP-A05	Security Misconfiguration	Pengiriman muatan JSON raksasa untuk membanjiri memori peladen	Batas ketat MAX_BODY 5MB dan isolasi pesan galat 500	TERPROTEKSI
OWASP-A06	Vulnerable Components	Penyusupan celah keamanan melalui pustaka pihak ketiga	Arsitektur dependensi minimalis berbasis pustaka native Node.js	TERPROTEKSI
OWASP-A07	Identification & Auth	Penggunaan token kedaluwarsa dan pemalsuan algoritma none	Validasi kedaluwarsa JWT dan penanganan sandi fail-closed	TERPROTEKSI
OWASP-A08	Software & Data Integrity	Manipulasi payload token hak akses dan penukaran fisik stiker QR aset	Verifikasi HMAC-SHA256 dan pencocokan nomor seri kode barang	TERPROTEKSI
OWASP-A09	Security Logging	Tindakan transaksi tanpa pencatatan identitas dan waktu	Pencatatan jejak audit otomatis pada skema basis data PostgreSQL	TERPROTEKSI
OWASP-A10	SSRF Vulnerability	Permintaan penjemputan URL alamat privat jaringan peladen	Penutupan akses penjemputan URL luar dinamis pada API serverless	TERPROTEKSI

Pengujian keamanan OWASP Top 10 membuktikan bahwa arsitektur perangkat lunak SESDIAN memiliki pertahanan kokoh terhadap ancaman siber internal maupun eksternal. Pembatasan wewenang berjenjang dan isolasi data perorangan menjamin akuntabilitas audit, sehingga tidak ada pegawai berpangkat admin yang dapat meminjam aset kantor tanpa pengawasan pihak lain di lingkungan Balai Penerapan Pengujian Mutu Hasil Perikanan.

BAB V CHAOS ENGINEERING DAN UJI KONKURENSI BASIS DATA

5.1 Konsep dan Model Transaksi Atomik Bersyarat

Dalam tata kelola Barang Milik Negara (BMN) pada instansi pemerintah seperti Balai Penerapan Pengujian Mutu Hasil Perikanan (BPPMKP), integritas sistem informasi diuji saat mengelola persediaan barang bernilai tinggi yang jumlah fisiknya sangat terbatas. Peralatan seperti proyektor aula, kamera inspeksi lapangan, atau drone pemantau sering kali hanya tersedia sebanyak 1 unit di gudang. Pada sistem inventaris konvensional yang tidak menerapkan kendali konkurensi ketat, kondisi ini sangat rawan menimbulkan kondisi pacu (*race condition*). Apabila dua atau lebih staf mengajukan peminjaman pada milidetik yang sama, kueri pembacaan konvensional (`SELECT stock_available`) dapat mendeteksi bahwa barang masih ada, lalu masing-masing transaksi secara terpisah mengeksekusi pemotongan stok (`UPDATE`). Hal tersebut memicu anomali stok bernilai negatif (-1 hingga -9), yang berujung pada sengketa fisik antar-pegawai di kantor dan mencederai transparansi tata kelola BMN.

Untuk memastikan keandalan mutlak dalam kondisi operasional paling kritis, tim pengembang menerapkan metodologi *Chaos Engineering* melalui berkas `tests/chaos-database.test.mjs`. Pendekatan ini secara sengaja menyuntikkan lonjakan lalu lintas paralel serentak (*burst concurrent traffic*), variasi keterlambatan jaringan acak (*jitter*), serta data korup ke dalam komponen inti sistem guna membuktikan bahwa basis data tetap stabil, konsisten, dan memenuhi kaidah atomisitas (ACID).

Arsitektur Pengujian dan Model Transaksi Atomik

Pengujian Chaos Engineering pada SESDIAN dirancang memanfaatkan modul pengujian resmi `node:test` serta modul asersi ketat `node:assert/strict`. Pengujian menyimulasikan model transaksi atomik yang menggabungkan verifikasi ketersediaan dan pemotongan stok ke dalam satu operasi tunggal:

```
UPDATE assets
SET stock_available = stock_available - 1, stock_borrowed = stock_borrowed + 1
WHERE id = $1 AND stock_available >= 1
RETURNING id;
```

Selain model kueri atomik, pengujian menyuntikkan variasi keterlambatan jaringan acak (*jitter*) antara 5 hingga 25 milidetik menggunakan fungsi `setTimeout` sebelum tiap transaksi dieksekusi. Hal ini mereplikasi fluktuasi sinyal koneksi internet pegawai kantor di lapangan saat lalu lintas sistem sedang padat, sehingga paket data tiba di server dengan selisih waktu tipis menyerupai kondisi nyata.

5.2 Tahapan Pengujian Beban Konkuren & Fluktuasi Jitter

Proses pengujian perebutan barang kritis dijalankan melalui empat tahapan terstruktur yang dijabarkan secara rinci:

Tahap 1: Pengondisian Awal Lingkungan (Pre-Condition Setup). Pengembang backend mengondisikan satu unit Proyektor Epson EB-X400 (ID 101) pada tabel aset sebelum simulasi dimulai. Persediaan proyektor diatur pada kondisi persediaan paling rawan di gudang, yaitu sisa barang tersedia persis satu unit (`stock_available = 1`) dan barang terpinjam bernilai nol (`stock_borrowed = 0`), tanpa permohonan aktif lain. Langkah ini menyimulasikan kondisi batas ekstrem: jika kendali konkurensi gagal, aset tunggal bernilai tinggi ini dapat disetujui untuk banyak staf sekaligus dan memicu stok bernilai negatif (-1 hingga -9).

Tahap 2: Pembangkitan Beban Konkuren & Injeksi Jitter (Traffic Generation & Jitter). Sepuluh akun pegawai fiktif (User ID 200 hingga 209) mengirimkan formulir peminjaman atas unit proyektor yang sama secara paralel pada milidetik yang sama menuju gerbang API SESDIAN. Skenario ini meniru lonjakan permohonan saat rapat koordinasi penting diumumkan mendadak. Pengujian mengeksekusi kesepuluh permintaan menggunakan konstruksi `Promise.all` yang dipadukan dengan jeda acak latensi jaringan (*jitter*) 5–25 ms, mereplikasi fluktuasi sinyal koneksi internet riil staf kantor di lapangan.

Tahap 3: Eksekusi Bersaing & Kunci Transaksional Atomik (Locking & Execution). Klaster basis data PostgreSQL menerima serbuan sepuluh transaksi konkuren yang saling berebut hak ubah atas baris data aset 101 melalui operasi kueri atomik bersyarat. Transaksi pertama yang tiba di server berhasil memenuhi klausa `WHERE stock_available >= 1`, mengunci baris data (*row-level lock*), memotong stok tersedia dari 1 menjadi 0, menaikkan stok terpinjam menjadi 1, dan menerbitkan izin pinjam sah. Sementara itu, sembilan transaksi lainnya mendapati stok telah habis sehingga pemotongan otomatis digagalkan dan server mengembalikan penolakan terkontrol tanpa deadlock.

Tahap 4: Verifikasi Asersi dan Status Akhir (Post-Condition Assertion). Modul pengujian `node:assert/strict` memvalidasi rekaman akhir pada memori server setelah seluruh transaksi selesai. Penguji mengaudit empat metrik integritas krusial: tepat satu permohonan berhasil (`successful.length === 1`), tepat sembilan permohonan ditolak (`rejected.length === 9`), stok persediaan di basis data bernilai nol (`stock_available === 0`), dan stok barang terpinjam bertambah satu (`stock_borrowed === 1`). Keberhasilan asersi ini membuktikan secara matematis bahwa sistem SESDIAN bebas dari cacat alokasi ganda dan konsisten terhadap pembukuan BMN.

5.3 Simulasi Ketahanan Anomali dan Serangan Internal

Selain pengujian persaingan stok, pengujian rekayasa kekacauan mencakup empat skenario simulasi serangan dan anomali data lainnya yang dijabarkan secara terperinci:

1. Simulasi Serangan Otorisasi Sendiri (Anti-Self-Approval Attack). Skenario di mana staf kantor pemegang peran istimewa (Admin BMN atau Verifikator) mencoba memanfaatkan akun khususnya untuk menyetujui atau memverifikasi permohonan pinjam aset miliknya sendiri. Tindakan ini dicoba pada saat staf membutuhkan barang dinas tanpa melalui pemeriksaan rekan kerja melalui formulir persetujuan dan pemindaian QR di antarmuka sistem. Pengujian ini dirancang untuk menutup celah korupsi, kolusi, atau penyalahgunaan wewenang internal agar seluruh pengeluaran aset BMN wajib melalui persetujuan pihak kedua (*four-eyes principle*). Sistem mendeteksi identitas pemohon: jika nilai parameter `isOwner = true`, sistem secara otomatis menolak aksi pada tiga gerbang (persetujuan awal, serah terima, dan pengembalian) dan memunculkan galat larangan resmi.

2. Simulasi Pemalsuan Tanda Tangan JWT (Token Tampering & Privilege Escalation). Skenario di mana pengguna biasa (staf biasa) mencoba merekayasa tiket login digital miliknya agar memperoleh hak wewenang setingkat Administrator. Aksi ini disimulasikan saat pengguna ingin membuka data rahasia seluruh aset atau mengubah status inventaris secara ilegal dengan membongkar memori peramban klien menuju gerbang otorisasi backend. Pengujian bertujuan membuktikan bahwa sistem SESDIAN kebal terhadap upaya manipulasi tiket digital tanpa kunci rahasia server. Penguji memecah format token `header.payload.signature`, mengubah isi payload dari `user` menjadi `admin`, dan mengirimkannya kembali ke server; fungsi `verifyToken` mendeteksi ketidakcocokan segel kriptografi HMAC-SHA256 dan seketika membatalkan akses dengan mengembalikan nilai kosong `null`.

3. Injeksi Hash Kriptografi Rusak (Fail-Closed Password Resilience). Skenario ketika basis data mengalami anomali transmisi atau kerusakan berkas sehingga data kata sandi pengguna tersimpan dalam kondisi cacat atau terpotong. Situasi ini dialami pengguna saat mencoba login ke aplikasi SESDIAN pada modul verifikasi sandi serverless backend. Pengujian dirancang untuk memastikan bahwa server tidak mengalami kegagalan fatal (*unhandled crash 500*) dan tidak membiarkan pintu masuk terbuka akibat kesalahan pembacaan format sandi. Penguji menyuntikkan tujuh variasi teks korup (string kosong, null, format tanpa pemisah salt, heksadesimal cacat) ke dalam fungsi `verifyPassword`; sistem terbukti tetap beroperasi stabil tanpa mati dan menerapkan asas *Fail-Closed* dengan mengunci pintu masuk secara aman guna melindungi seluruh data aset milik BPPMKP.

4. Injeksi Kueri SQL Berbahaya (SQL Injection Sanitization). Skenario di mana penyerang memasukkan perintah SQL manipulatif seperti `'; DROP TABLE assets; --` atau tautologi `' OR '1'='1`. Serangan diluncurkan melalui formulir pencarian barang dan kotak input pembacaan kode QR saat pengguna memasukkan data pencarian. Pengujian dilaksanakan untuk menjamin data inventaris tidak dapat dihapus atau dibocorkan oleh masukan karakter asing berbahaya. Sistem SESDIAN memanfaatkan teknologi *tagged template literals* pada driver Neon Postgres yang secara otomatis memisahkan teks perintah SQL dari nilai parameter input, sehingga seluruh teks berbahaya diperlakukan murni sebagai string pencarian biasa dan tidak dieksekusi sebagai perintah basis data.

5.4 Matriks Evaluasi Konsistensi Basis Data

Tabel 4 merangkum seluruh metrik evaluasi hasil pengujian Chaos Engineering dan ketahanan basis data:

ID Uji	Skenario Uji Chaos	Metode & Beban Uji	Hasil Verifikasi Data	Status
CHAOS-01	Persaingan Transaksi Konkuren (Race Condition)	10 Request paralel serentak, jitter 5-25ms, stok awal = 1	1 Sukses, 9 Ditolak terkontrol, Stok akhir = 0 (Tidak minus)	PASS
CHAOS-02	Pencegahan Approval Mandiri (Anti-Self-Approval)	Admin/Verifikator menyetujui pinjaman sendiri (isOwner=true)	3 Gerbang diblokir: izin ditolak dengan pesan peringatan resmi	PASS
CHAOS-03	Pemalsuan Tanda Tangan JWT (Privilege Escalation)	Eskalasi payload 'user' menjadi 'admin' tanpa kunci privat	HMAC-SHA256 mismatch: token ditolak (return null)	PASS
CHAOS-04	Resiliensi Hash Sandi Korup (Fail-Closed)	Injeksi 7 varian string korup & non-hex pada scrypt verify	Worker tetap stabil (zero crash), return false secara aman	PASS
CHAOS-05	Sanitasi Karakter SQL Injeksi	Injeksi string tautologi, stacked query, dan tag XSS	Tagged template parameterization Neon Postgres 100% aman	PASS

Pembahasan Karakteristik Transaksi ACID

Hasil pengujian membuktikan bahwa sistem SESDIAN memenuhi empat karakteristik utama transaksi basis data relasional (ACID):

1. Atomisitas (Atomicity): Pemotongan stok ketersediaan dan penambahan stok terpinjam dieksekusi dalam satu operasi tunggal bersyarat. Tidak pernah terjadi pemotongan stok parsial yang menggantung jika status peminjaman gagal tercatat.

2. Konsistensi (Consistency): Aturan bisnis persediaan bernilai non-negatif (`stock_available >= 0`) dipertahankan secara absolut. Seluruh pembaruan data mematuhi batasan integritas skema PostgreSQL.

3. Isolasi (Isolation): Kunci tingkat baris (*row-level locking*) memastikan transaksi konkuren diproses secara berurutan tanpa interferensi pembacaan kotor antar-sesi pengguna.

4. Ketahanan (Durability): Setiap transaksi yang berhasil terkonfirmasi ditulis secara permanen ke media penyimpanan penyimpanan klaster Neon Postgres Serverless dengan jaminan replikasi data aman.

BAB VI PENGUJIAN OTOMATIS END-TO-END PLAYWRIGHT

Pengujian akhir fungsionalitas antarmuka dijalankan secara terotomasi menggunakan mesin peramban Playwright pada kanal Microsoft Edge melalui berkas `scripts/test-e2e.mjs`. Pengujian ini menyimulasikan interaksi klik pengguna, pengisian formulir data, pembukaan kotak dialog modal, penanganan toast alert, serta inspeksi elemen DOM secara langsung pada sesi peramban sesungguhnya.

6.1 Arsitektur Pengujian Antarmuka Headless Peramban

Lingkungan otomasi Playwright dijalankan dalam mode headless dengan resolusi viewport 1280x1024 piksel. Setiap skenario pengujian menginisialisasi sesi terisolasi menggunakan token autentikasi JWT dinamis, memantau siklus pertukaran data API hingga status `networkidle` terpenuhi, dan melakukan asersi terhadap elemen antarmuka melalui Playwright Locator API guna memastikan komponen web bebas dari keterlambatan render atau galat asinkron.

6.2 Matriks 21 Pengujian Otomatis Playwright

Tabel 5 menyajikan rincian hasil 21 pengujian otomatis Playwright yang mencakup seluruh modul sistem SESDIAN:

Grup Modul	Skenario Uji Fungsional Antarmuka	Kriteria Asersi DOM & Respon Server	Hasil Uji
Backend API	GET /categories, /rooms, /assets, /reports, /notify?cron=overdue	Status HTTP 200, array data valid, struktur JSON utuh (5 Uji)	5 / 5 PASS
Halaman Login	Render kartu login, form NIP/sandi, dan petunjuk kredensial akun	Elemen input form interaktif, kontainer kartu terpusat (1 Uji)	1 / 1 PASS
Dashboard Utama	Navigasi bilah sisi, kartu metrik statistik BMN, dan tabel riwayat	Sidebar render sempurna, nilai hitungan BMN tampil akurat (3 Uji)	3 / 3 PASS
Opname Ruang	Render 6 kartu ruangan, dialog modal, audit QR, ekspor berkas CSV	Grid ruangan tampil, modal audit aktif, unduhan CSV valid (5 Uji)	5 / 5 PASS
Laporan Aset	Ringkasan metrik BMN, filter tanggal, kontainer grafik tren visual	Filter aktif tanpa galat DOM, kontainer grafik ter-render (3 Uji)	3 / 3 PASS
Ekspor Laporan	Ekspor rekapitulasi data peminjaman BMN ke format berkas CSV	Unduhan file CSV valid dengan header kolom BMN lengkap (1 Uji)	1 / 1 PASS
Peminjaman	Antrean permohonan dua lapis dan pemulihan stok unit BMN	Transisi pending-approved-borrowed-returned valid (3 Uji)	3 / 3 PASS

6.3 Analisis Kinerja Render dan Waktu Respons UI

Seluruh 21 skenario otomasi Playwright berhasil diselesaikan dalam durasi total 18,4 detik dengan rata-rata waktu eksekusi 876 milidetik per skenario. Tidak ditemukan adanya kendala kemacetan elemen antarmuka, kebocoran memori pada browser context, maupun peristiwa waktu tunggu habis (*timeout failure*), membuktikan bahwa antarmuka web SESDIAN memiliki responsivitas tinggi untuk operasional harian di BPPMKP.

BAB VII MATRIKS REKAPITULASI DAN BERITA ACARA KELAYAKAN

Berdasarkan seluruh rangkaian evaluasi yang telah diselesaikan pada Milestone M5, pengujian perangkat lunak SESDIAN mencakup lima pilar evaluasi komprehensif mulai dari verifikasi algoritma internal backend, antarmuka pengguna, keamanan siber, ketahanan konkurensi data, hingga otomasi alur kerja antarmuka peramban.

7.1 Matriks Rekapitulasi Pengujian Sistem

Tabel 6 menyajikan rekapitulasi tingkat kelulusan pada seluruh tahapan pengujian perangkat lunak SESDIAN:

No	Kategori Pengujian	Lingkup dan Target Komponen	Jumlah Uji	Hasil & Status
1	**Pengujian Modul (node:test)**	Logika sandi scrypt, integritas token JWT, aturan peminjaman	17 Skenario	**17 / 17 PASS**
2	**Pengujian Blackbox API**	Validasi endpoint REST serverless, kode status HTTP, JSON	6 Skenario	**6 / 6 PASS**
3	**Pengujian OWASP Top 10**	Pertahanan A01 s.d A10 terhadap ancaman siber aplikasi web	10 Skenario	**10 / 10 PASS**
4	**Rekayasa Chaos Engineering**	10 User konkuren, fluktuasi jitter, transaksi atomik ACID	5 Skenario	**5 / 5 PASS**
5	**Otomasi Antarmuka Playwright**	Pengujian end-to-end headless peramban pada seluruh halaman	21 Skenario	**21 / 21 PASS**
		TOTAL PENGUJIAN KESELURUHAN SISTEM:	**59 Skenario**	**100% LULUS**

7.2 Berita Acara Pengesahan Kelayakan Sistem (BAP-KSI)

Nomor Dokumen: 042/BA-PKS/BPPMKP/XI/2026. Pada hari ini, Rabu tanggal 11 November 2026, bertempat di Balai Penerapan Pengujian Mutu Hasil Perikanan (BPPMKP), tim pengembang perangkat lunak SESDIAN menyatakan bahwa seluruh 59 skenario uji pada Milestone M5 telah diselesaikan dengan tingkat kelulusan 100% dan tidak ditemukan cacat berkategori kritis maupun mayor (*zero critical defects*). Sistem informasi dinyatakan **MEMENUHI SYARAT KELAYAKAN (PRODUCTION-READY)** untuk diterapkan pada lingkungan operasional BPPMKP.

Penguji Kualitas (QA),	Pengembang Backend,	Manajer Proyek,
Anselmus Herpin Hasugian	**Adi Septriansyah**	**Febrian Valentino Nugroho**
NIM. 121140134 · QA Lead	NIM. 121140027 · Backend Lead	NIM. 123140034 · Project Manager